

Certifikáty a PKI

NMMB332 Aplikovaná kryptografie

Jakub Töpfer

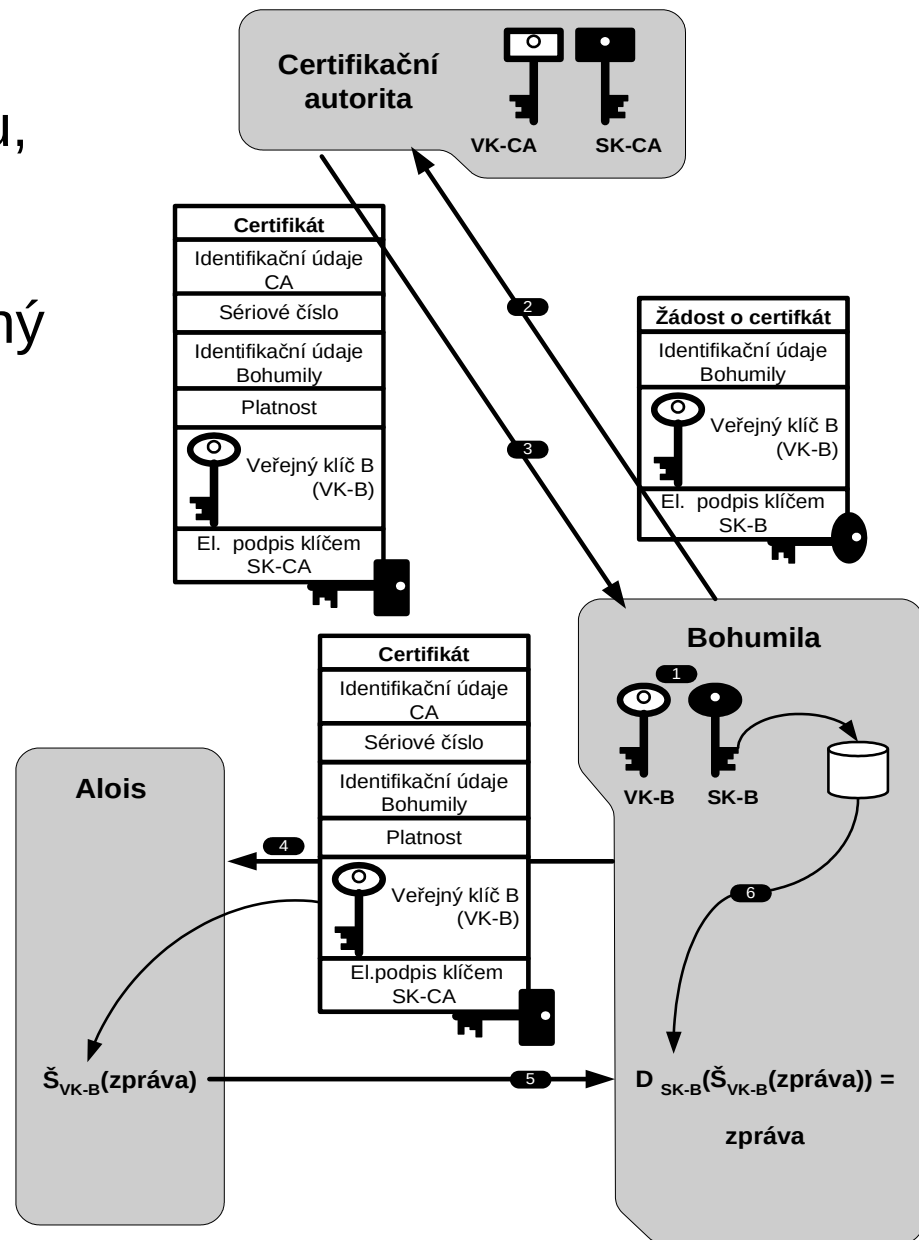
Certifikát

- Standard X.509
- Propojení vlastnictví privátního asymetrického klíče s reálnou identitou (osoby, serveru, ...)
- Využití důvěryhodné třetí strany
= certifikační autorita
- Public key infrastructure (PKI)

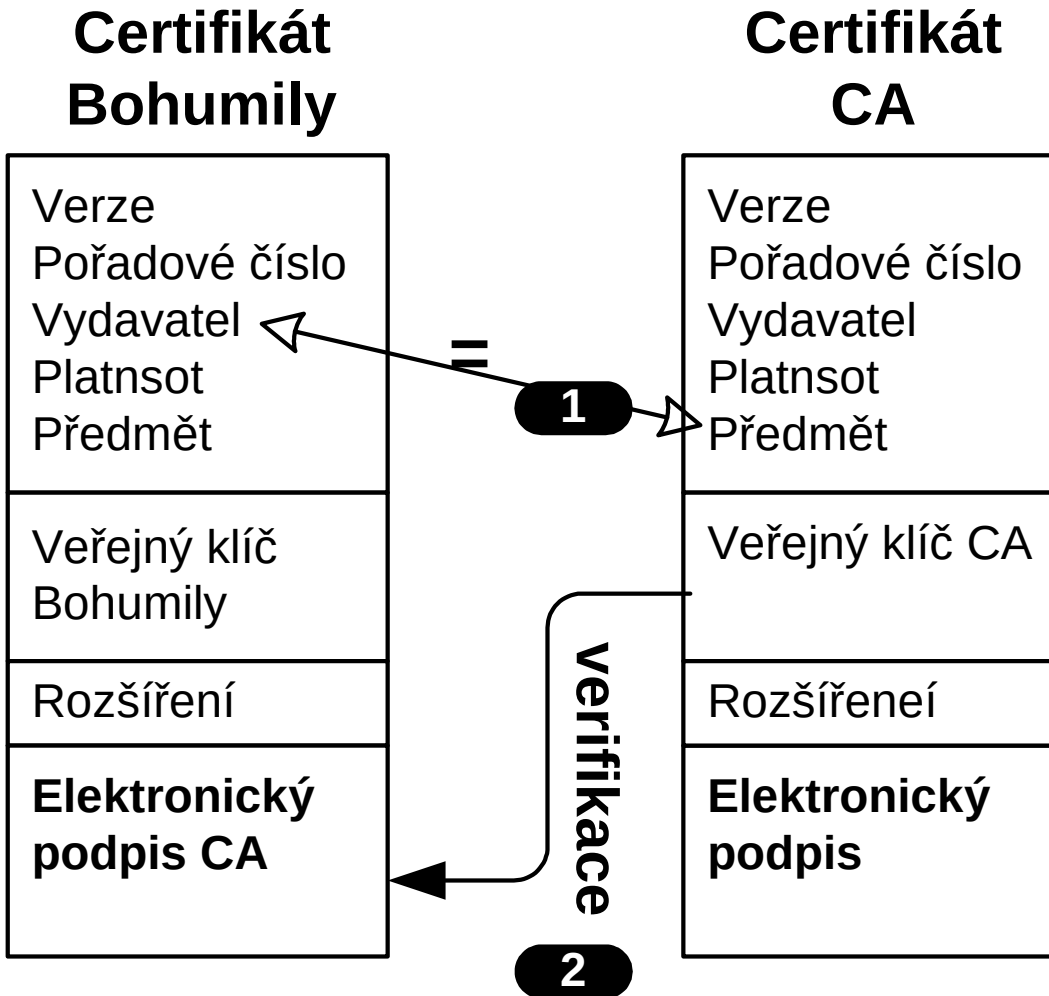
Základní představa

Alois chce Bohumile poslat zprávu,
k tomu potřebuje její veřejný klíč.

Chce mít jistotu, že používá veřejný
klíč, který opravdu patří Bohumile.



Zjednodušená verifikace



Kořenová CA

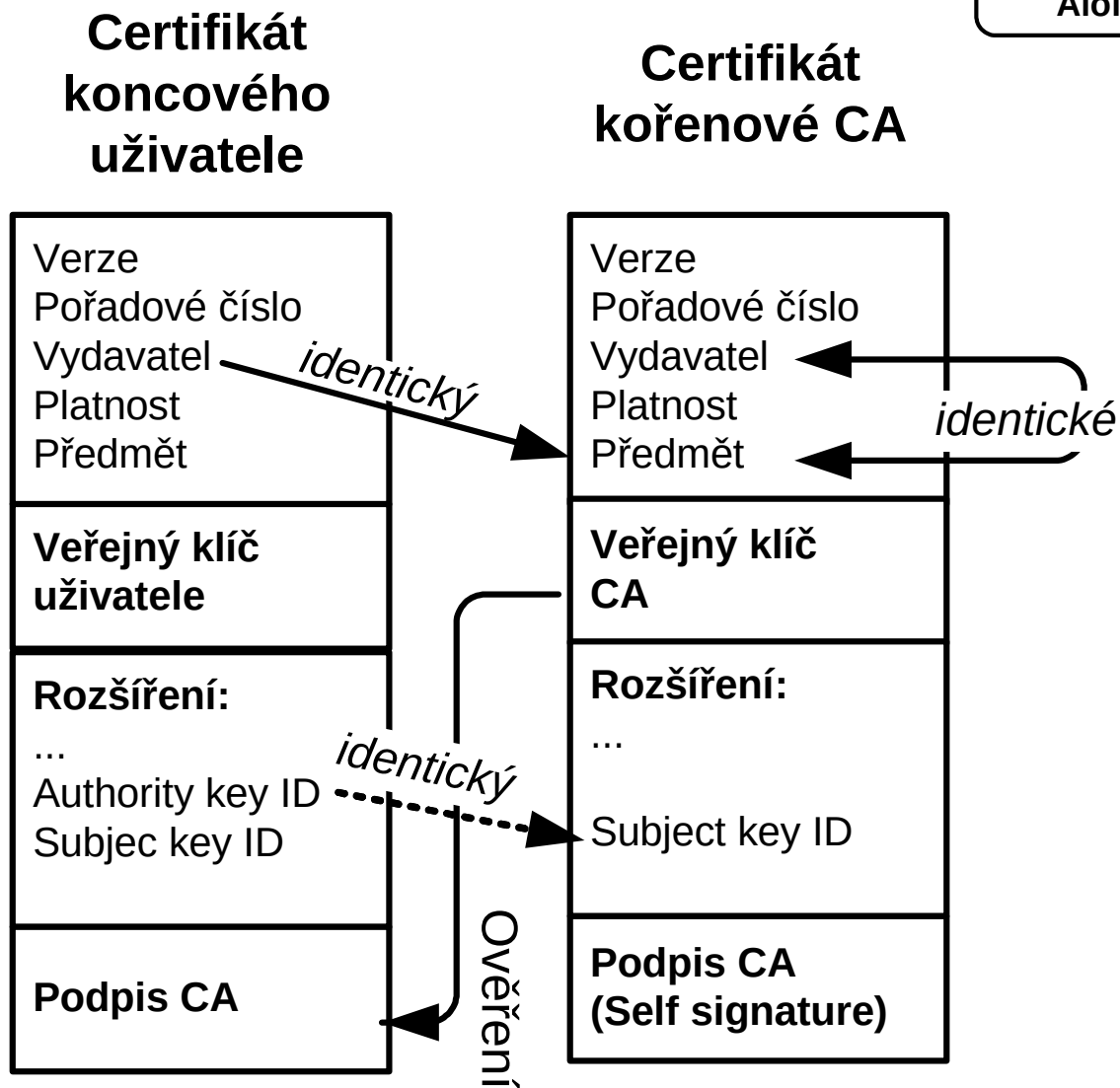
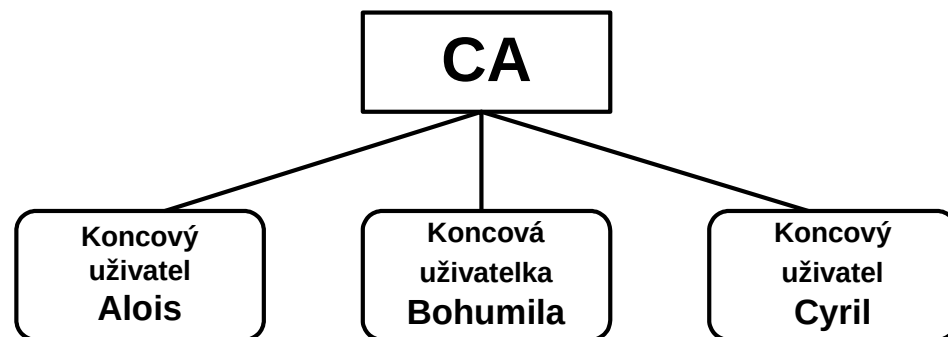
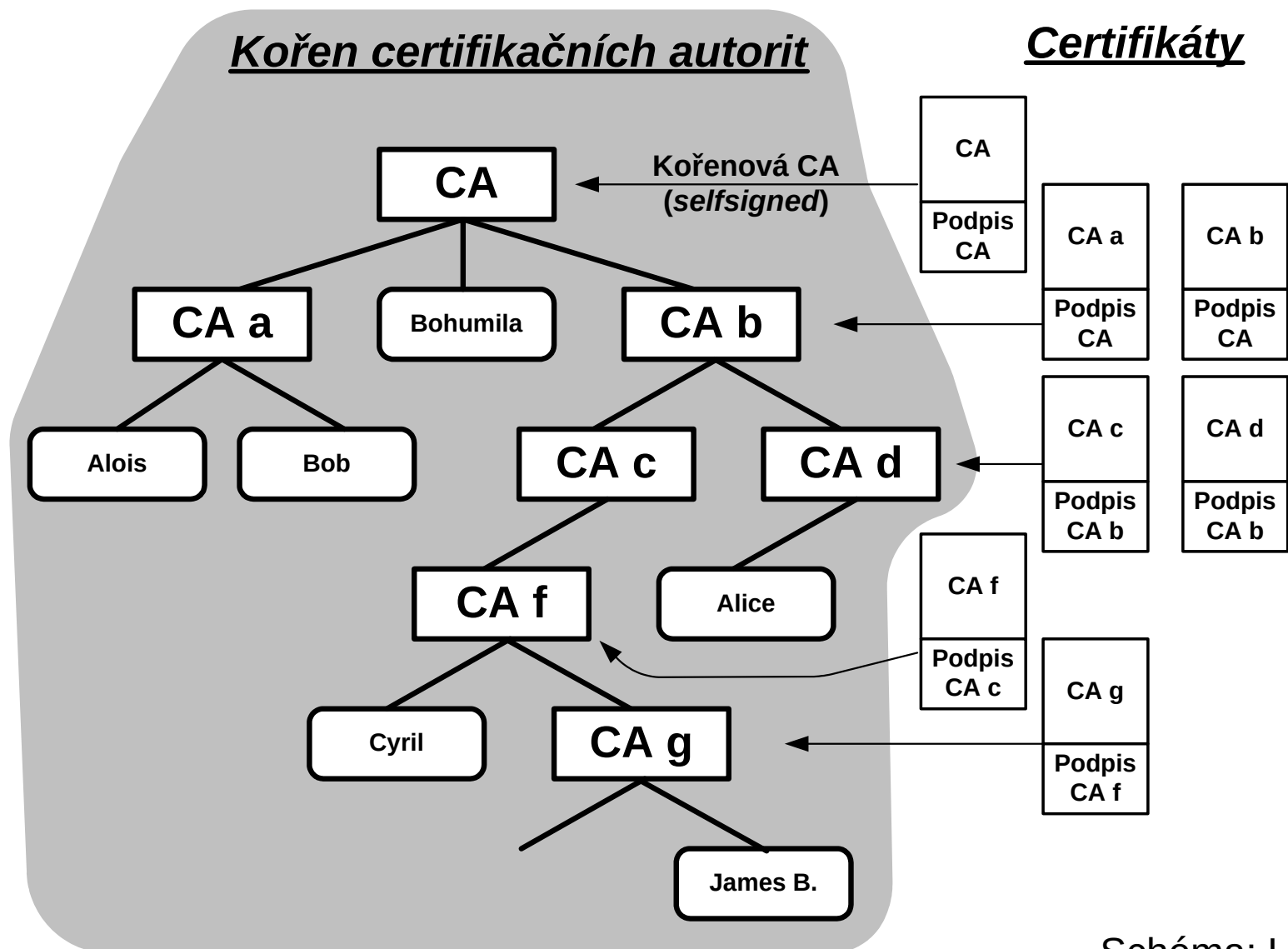


Schéma: Libor Dostálek

Stromová struktura



Sestavení certifikační cesty

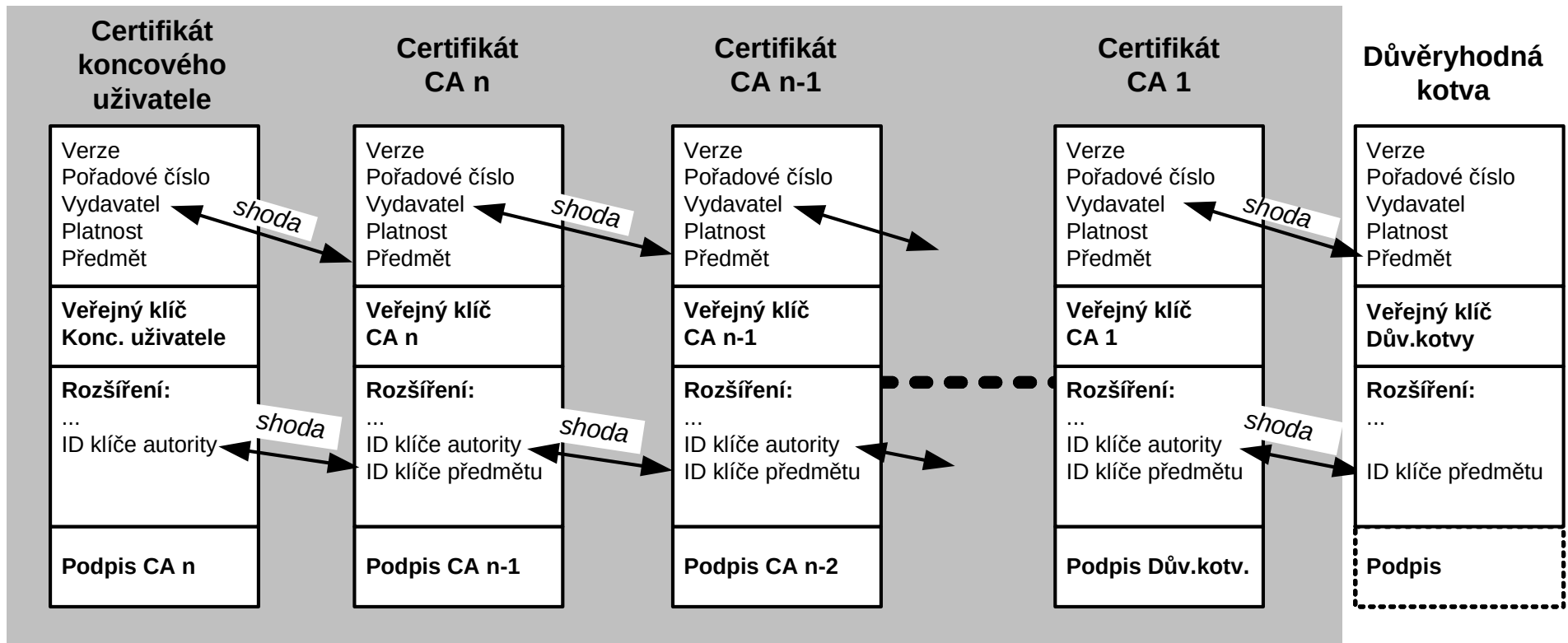


Schéma: Libor Dostálek

Ověřování certifikační cesty

Začíná od důvěryhodné kotvy (obráceně než sestavování)

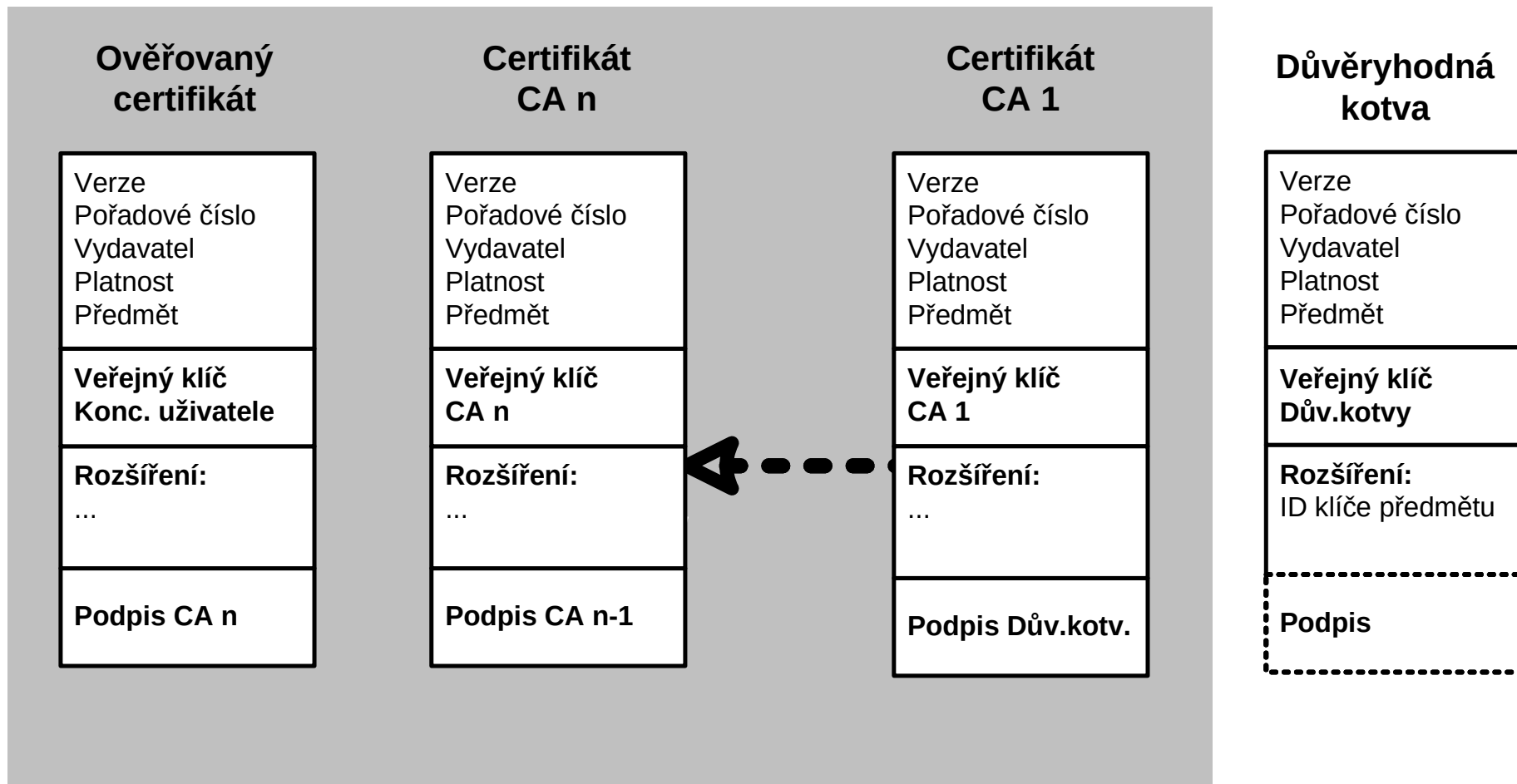
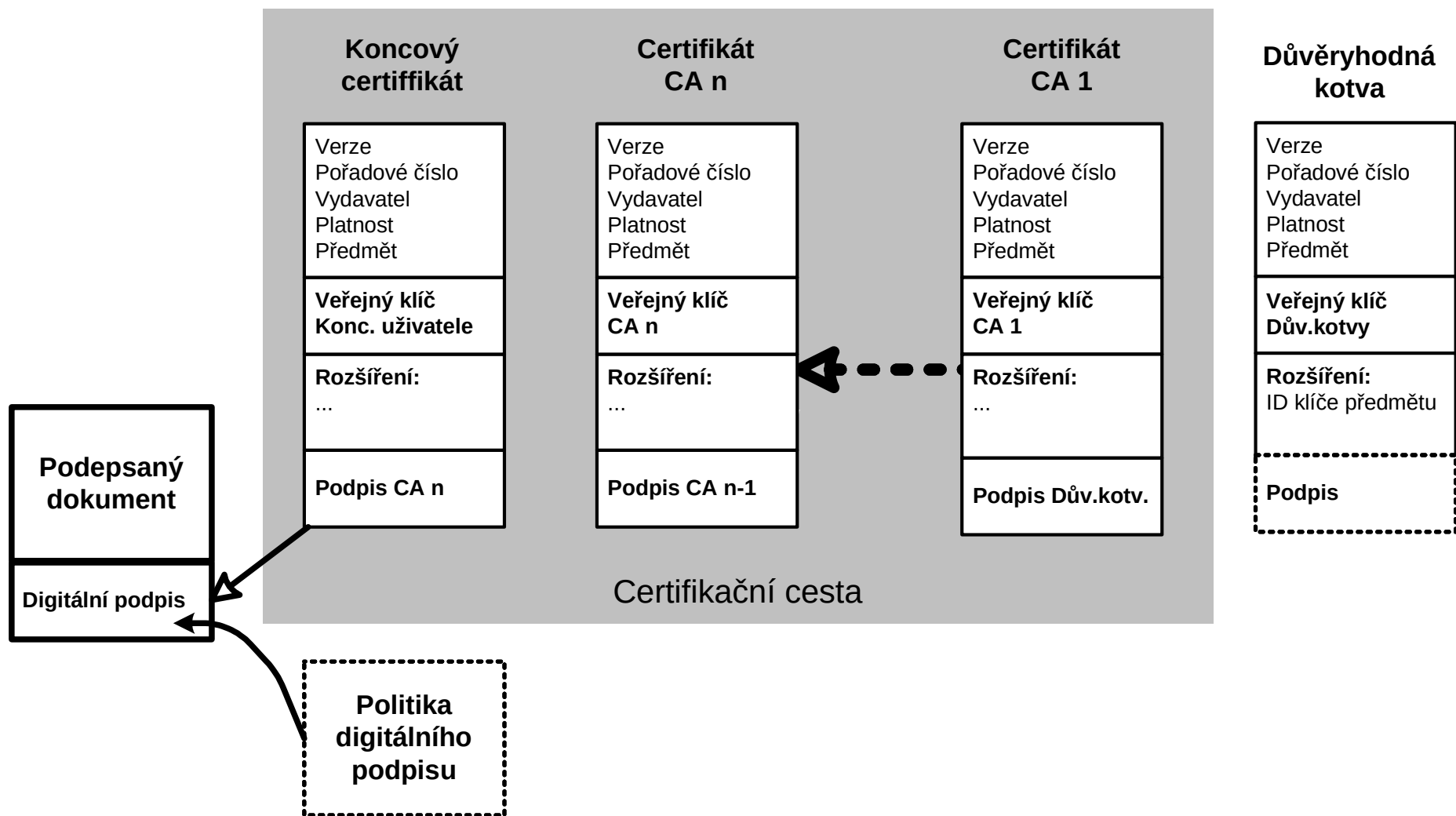


Schéma: Libor Dostálek

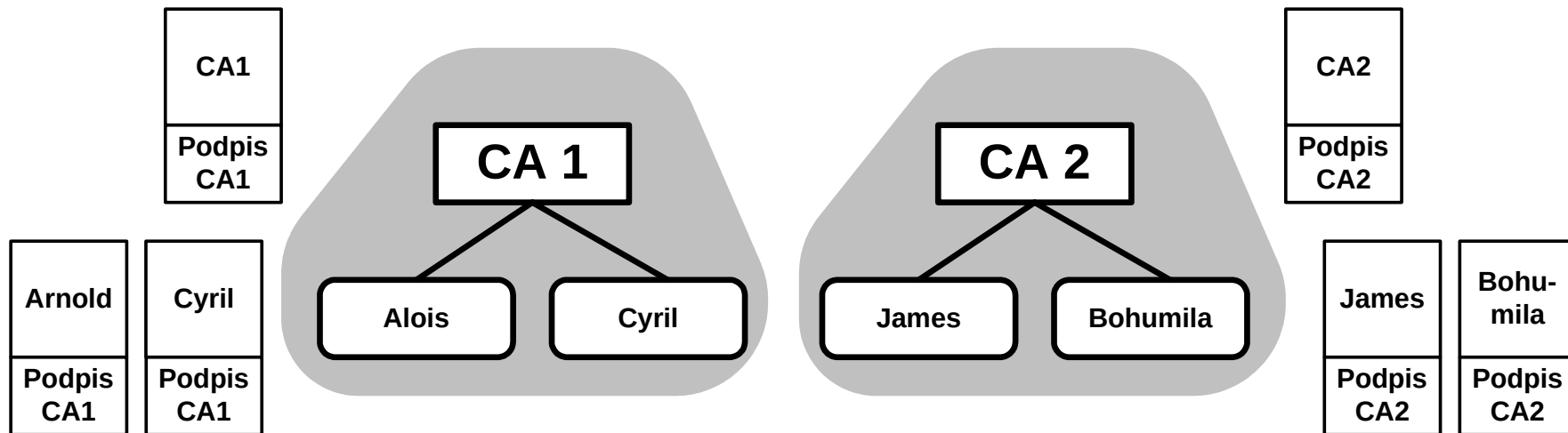
Ověření certifikátu v cestě

- **Vydavatel** certifikátu **x** je **předmětem** certifikátu **x-1**
- Ověřit **digitální podpis** certifikátu **x** pomocí certifikátu **x-1**
- Aktuální **čas** v době platnosti certifikátu
- Certifikát **nebyl odvolán** (revoked)
- **Jména** uvedená v předmětu certifikátu a v rozšíření Alternativní jména předmětu **odpovídají omezením** vyplývajícím z rozšíření Omezení jmen v předchozích certifikátech certifikační cesty
- Verifikují se rozšíření spojená s **certifikačními politikami**

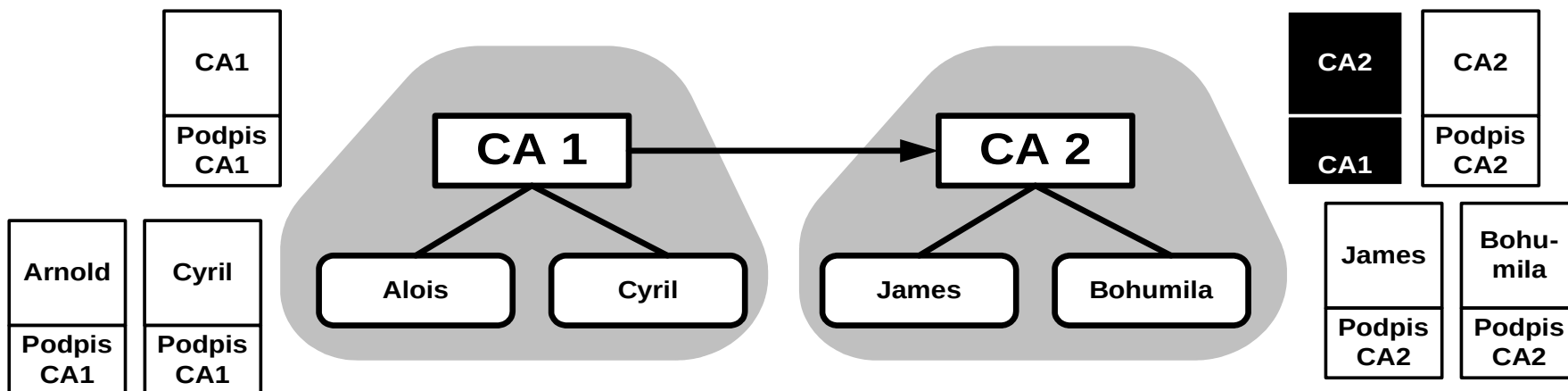
Ověření podpisu



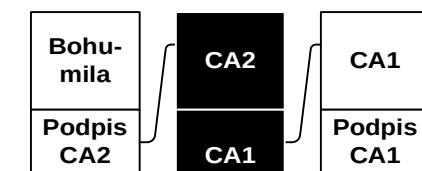
Vzájemná důvěra mezi CA



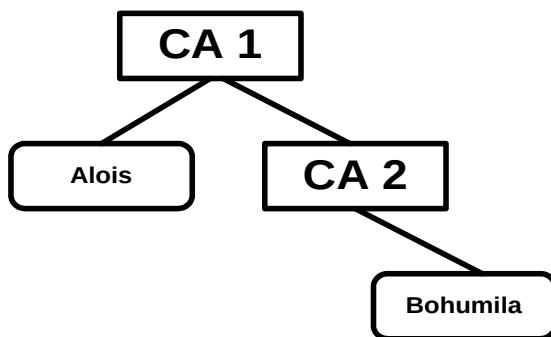
Křížová certifikace



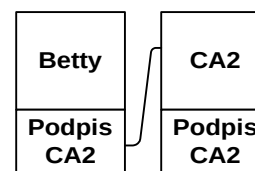
Aloisův úhel pohledu



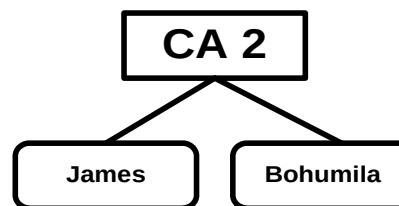
Arnoldova certifikační cesta



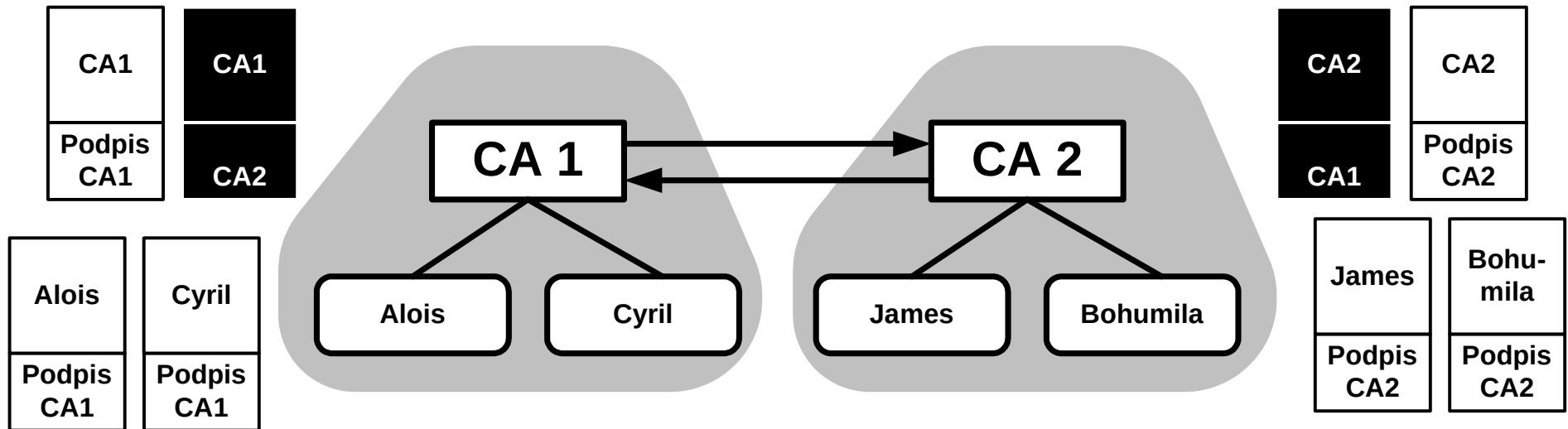
Jamesův úhel pohledu



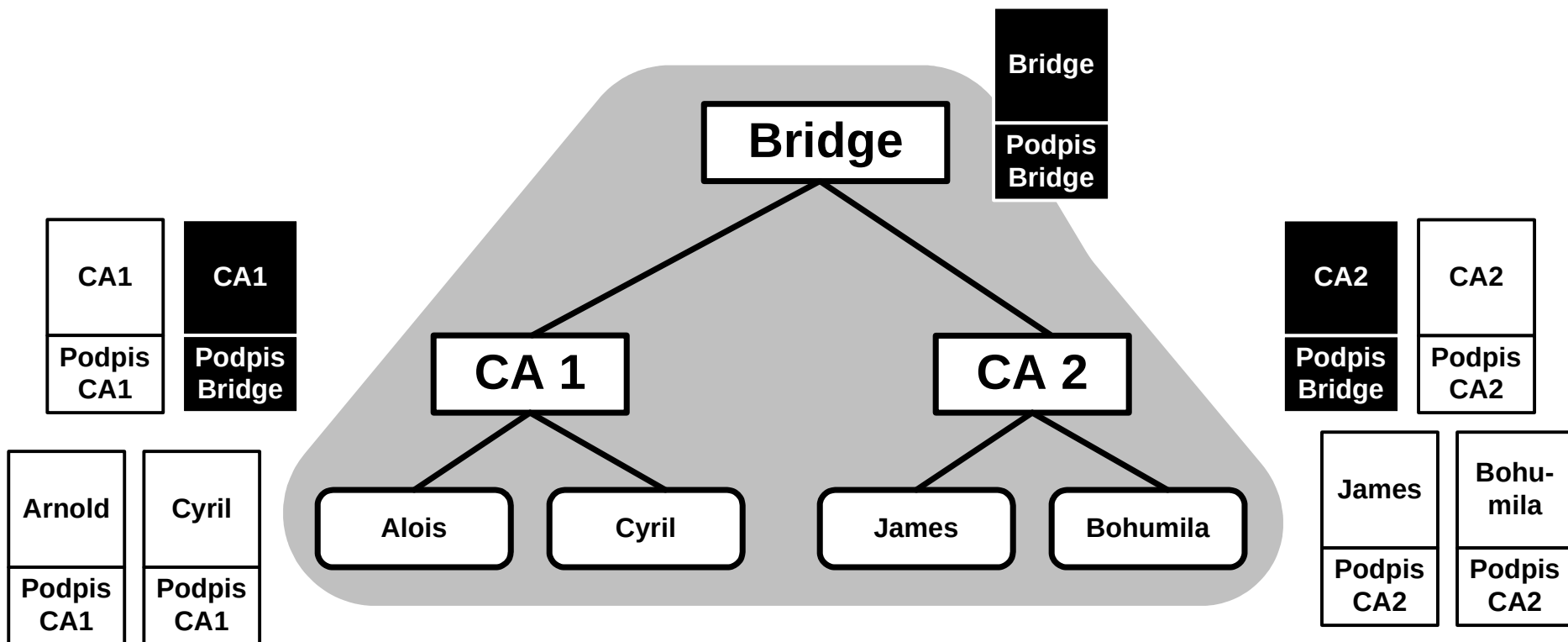
Bohumilina certifikační cesta



Vzájemná křížová certifikace



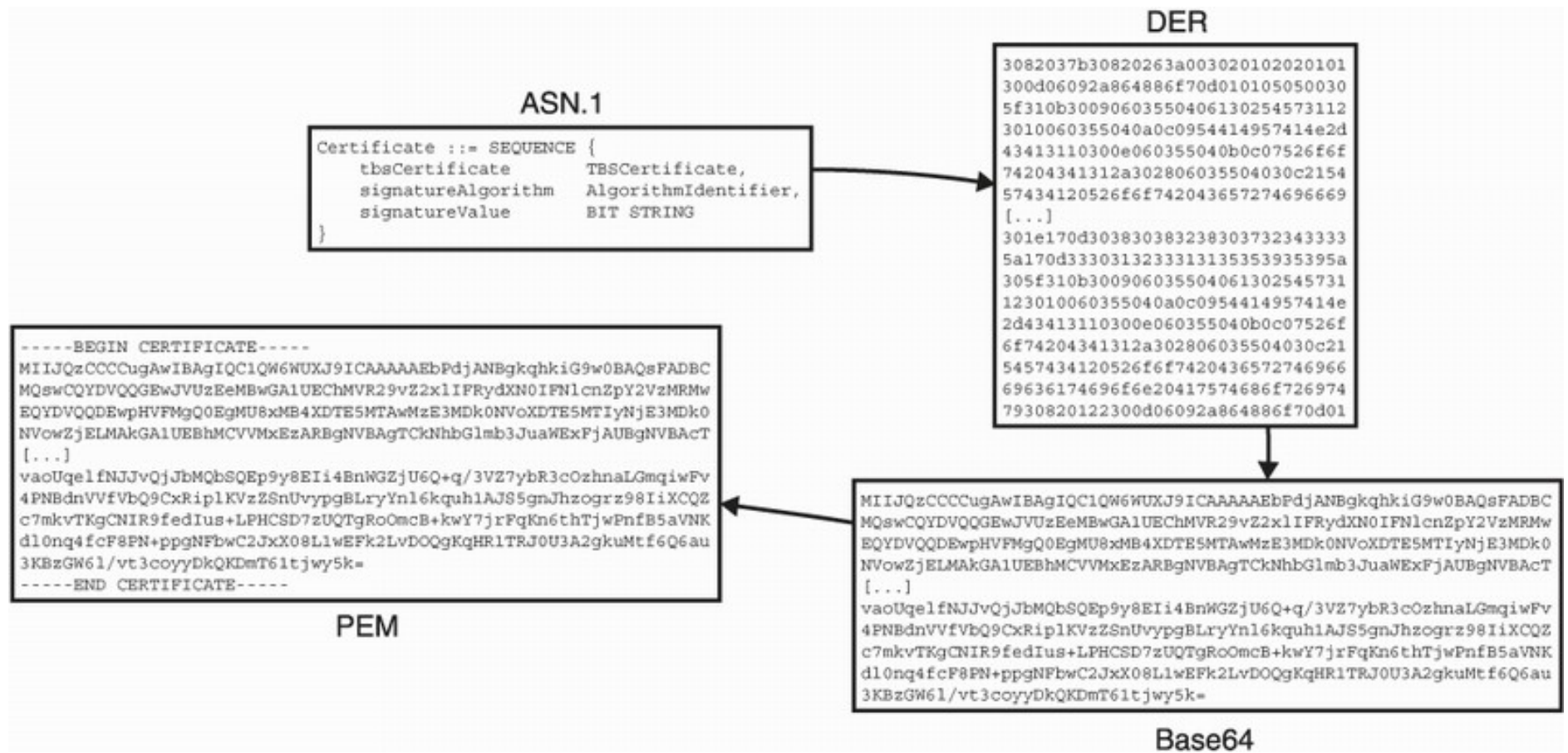
Most



Důvěryhodné kotvy

- Často distribuovány spolu s OS
- Některé prohlížeče (Firefox) používají vlastní seznamy důvěryhodných CA
- Lze přidávat dle potřeby uživatele

Certifikát technicky



Certifikát technicky

- Pro zápis struktur jazyk ASN.1
- ASN.1 struktura zakódovaná ve formátu DER
 - `certificate.der`
- DER zakódované base64 + hlavička a patička → PEM
 - `certificate.pem`

ASN.1

- Abstraktní jazyk pro popis typů dat
- Příklad

```
ZjistovaciOtazky DEFINITIONS ::= BEGIN
    ZjistovaciOtazka ::= SEQUENCE {
        poradoveCislo    INTEGER,
        otazka            UTF8String
    }
    OdpovedAnoNe ::= SEQUENCE {
        cisloOtazky      INTEGER,
        odpoved          BOOLEAN
    }
END
```

Kódování BER/DER

- Způsob, jak zapsat ASN.1 strukturu
- Základní schéma

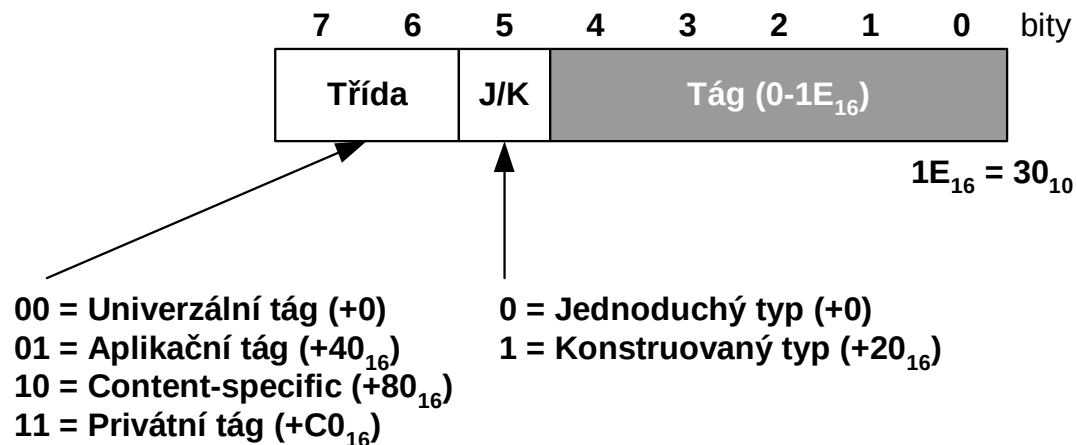


- V rámci bytu nejvýznamnější bit vlevo

Typ dat

Pole typ dat pro tágý menší než 31

(vejde se do jednoho bajtu)



Pole typ dat pro tágý větší než 30

(skládá se z více bajtů)

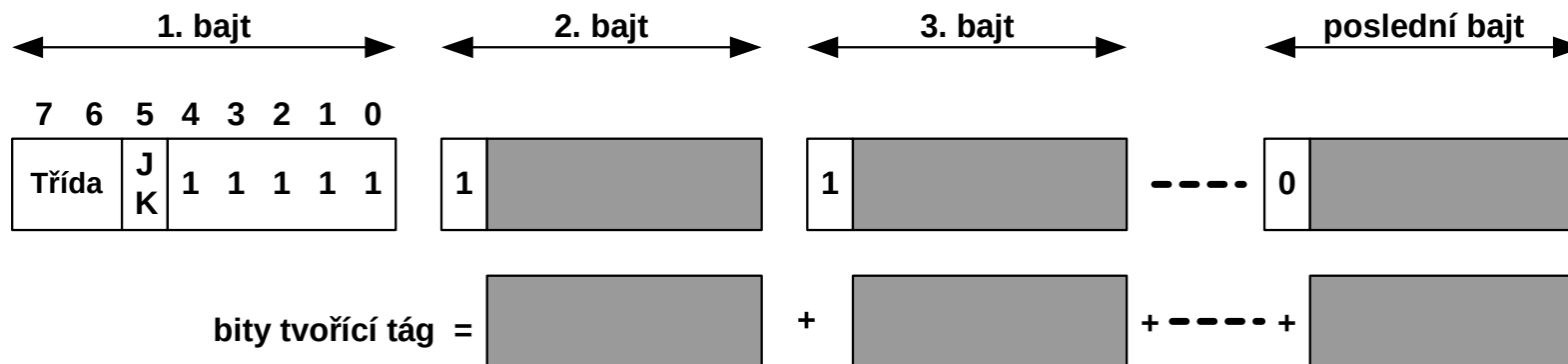


Schéma: Libor Dostálek

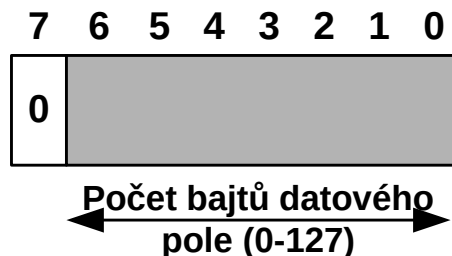
Univerzální typy

Typ	Tág DEC	Tág HEX	Význam
END OF CONT. (EOC)	0	0	Konec pole dat v kódování BER pro případ, že data jsou nedefinované délky
BOOLEAN	1	1	Hodnoty TRUE a FALSE
INTEGER	2	2	Celé číslo
BIT STRING	3	3	Řetězec bitů
OCTET STRING	4	4	Řetězec bytů (blíže nespecifikovaný)
NULL	5	5	Prázdný typ
OBJECT IDENT.	6	6	Identifikátor objektu
REAL	9	6	Reálné číslo {Mantisa, Base, Exponent}
ENUMERATED	10	A	Výčet hodnot (nemusí být uspořádaný)
UTF8String	12	C	Řetězec UTF8
SEQUENCE a SEQUENCE OF	16	10	Uspořádaná posloupnost prvků, SEQUENCE OF může být i prázdná
SET a SET OF prázdná.	17	11	Množina prvků (neuspořádaná), SET OF i
NumericString	18	12	0-9 a mezera
PrintableString	19	13	0-9 a-z A-Z mezera ' () + , - . / : = ?
T61String	20	14	TeleText podle doporučení T.61
VideotexString	21	15	
IA5String	22	16	skoro ASCII (přesněji IA5)
UTCTime	23	17	Čas
GeneralisedTime	24	18	Čas
GraphicString	25	19	Grafické znaky
VisibleString	26	1A	Sada 6 a SPACE
GeneralString	27	1B	Znaky + grafické znaky + DELETE
UniversalString	28	1C	UCS-4
BMPString	30	1E	UCS-2

Délka dat

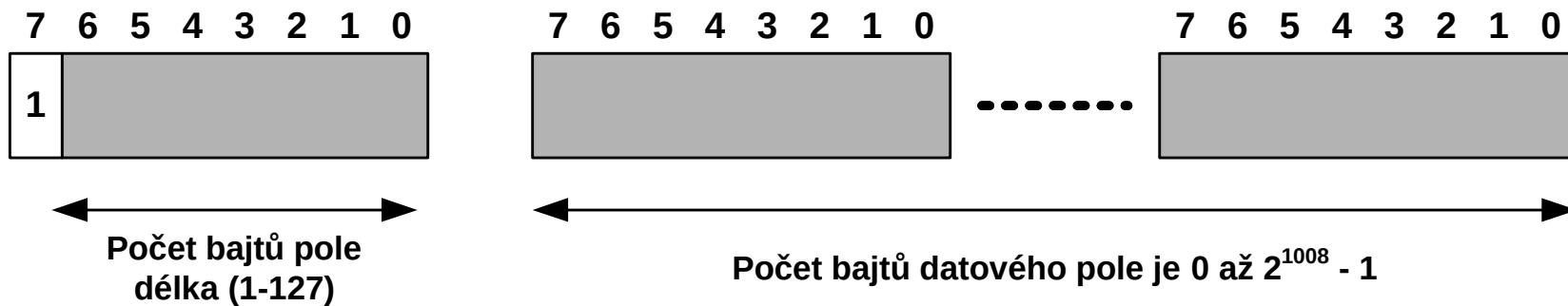
Krátká forma pole délka

(jeden bajt)



Dlouhá forma pole délka

(více bajtů)



Příklad

```
Student ::= SEQUENCE {  
    prijmeni    Prijmeni,  
    jmeno       Jmeno,  
    rocnik      Rocnik  
}
```

Kde

```
Prijmeni    ::= IA5string,  
Jmeno       ::= IA5string,  
Rocnik      ::= INTEGER}
```

Příklad

Jan Korda, 3. ročník

Příjmení: 16 05 4b 6f 72 64 61

Jméno: 16 03 4a 61 6e

Ročník: 02 01 03

Dohromady: 30 0f 16 05 4b 6f 72 64
61 16 03 4a 61 6e 02 01 03

Object identifier

- Existuje globální stromová struktura objektů
- Object identifier je zápis cesty v této struktuře, např.
1.2.840.113549.1.1.11
= sha256WithRSAEncryption
- <https://www.alvestrand.no/objectid/top.html>

Base64

- Převod binárních dat na tisknutelné znaky
- A..Z a..z 0..9 + /
- Byty za sebe, rozdělit po šesticích, každá šestice kódovaná jedním tisknutelným znakem dle převodní tabulky
- Na konci padding = podle toho, kolik 0 bitů bylo potřeba přidat do posledního bloku (2 → =, 4 → ==), občas nepovinné

Base64 - tabulka

Index	Binary	Char	Index	Binary	Char	Index	Binary	Char	Index	Binary	Char
0	000000	A	16	010000	Q	32	100000	g	48	110000	w
1	000001	B	17	010001	R	33	100001	h	49	110001	x
2	000010	C	18	010010	S	34	100010	i	50	110010	y
3	000011	D	19	010011	T	35	100011	j	51	110011	z
4	000100	E	20	010100	U	36	100100	k	52	110100	0
5	000101	F	21	010101	V	37	100101	l	53	110101	1
6	000110	G	22	010110	W	38	100110	m	54	110110	2
7	000111	H	23	010111	X	39	100111	n	55	110111	3
8	001000	I	24	011000	Y	40	101000	o	56	111000	4
9	001001	J	25	011001	Z	41	101001	p	57	111001	5
10	001010	K	26	011010	a	42	101010	q	58	111010	6
11	001011	L	27	011011	b	43	101011	r	59	111011	7
12	001100	M	28	011100	c	44	101100	s	60	111100	8
13	001101	N	29	011101	d	45	101101	t	61	111101	9
14	001110	O	30	011110	e	46	101110	u	62	111110	+
15	001111	P	31	011111	f	47	101111	v	63	111111	/
Padding		=									

Base64 - příklad

Source	Text (ASCII)	M								a								n							
	Octets	77 (0x4d)								97 (0x61)								110 (0x6e)							
Bits		0	1	0	0	1	1	0	1	0	1	1	0	0	0	0	1	0	1	1	0	1	1	1	0
Base64 encoded	Sextets	19								22								5							
	Character	T								W								F							
	Octets	84 (0x54)								87 (0x57)								70 (0x46)							

Source	Text (ASCII)	M								a															
	Octets	77 (0x4d)								97 (0x61)															
Bits		0	1	0	0	1	1	0	1	0	1	1	0	0	0	0	1	0	0						
Base64 encoded	Sextets	19								22								4							
	Character	T								W								E							
	Octets	84 (0x54)								87 (0x57)								69 (0x45)							

Certifikát technicky

Certificate

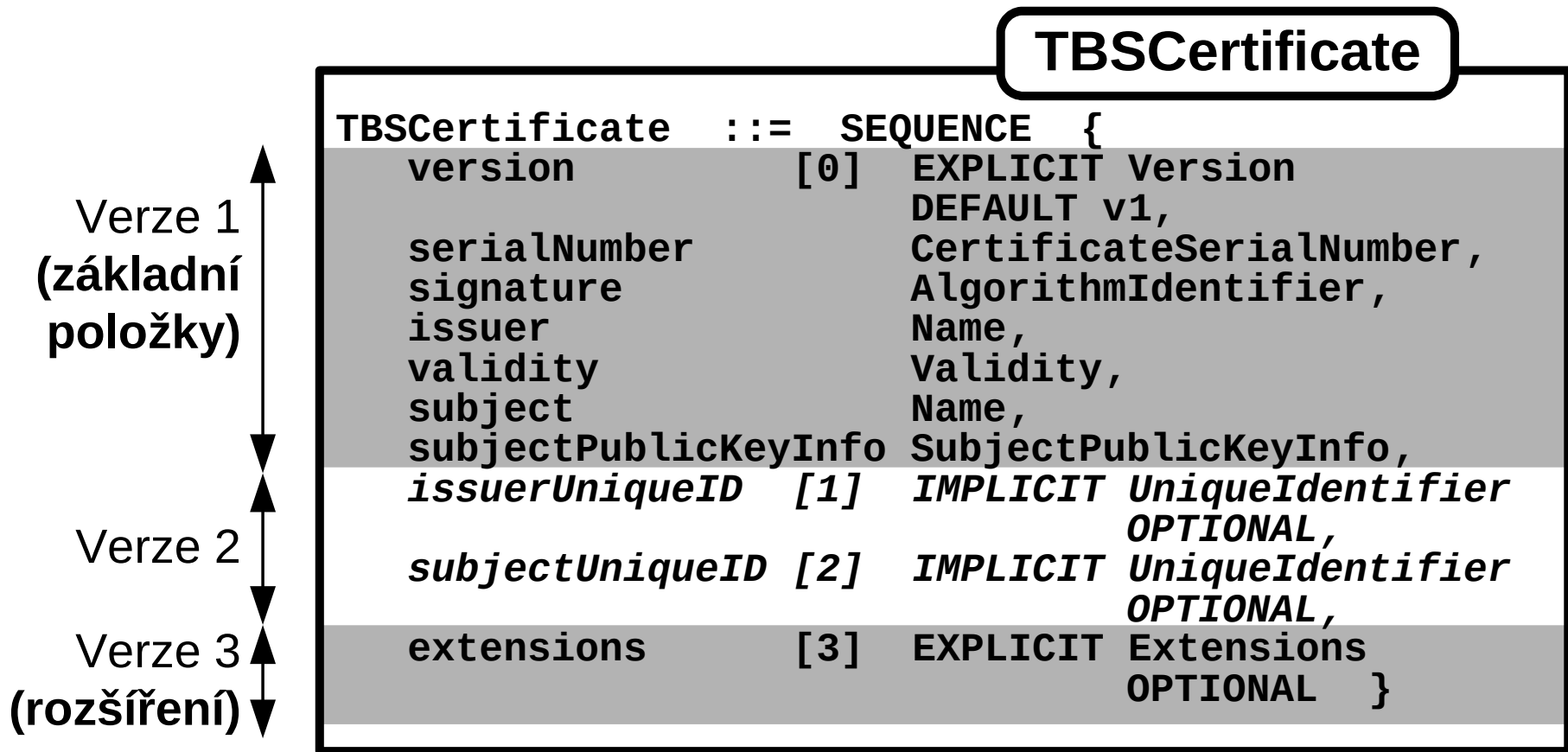
```
Certificate ::= SEQUENCE {  
    tbsCertificate TSCertificate,  
    signatureAlgorithm AlgorithmIdentifier,  
    signatureValue BIT STRING }
```

TBSCertificate

```
TBSCertificate ::= SEQUENCE {  
    version [0] EXPLICIT Version  
        DEFAULT v1,  
    serialNumber CertificateSerialNumber,  
    signature AlgorithmIdentifier,  
    issuer Name,  
    validity Validity,  
    subject Name,  
    subjectPublicKeyInfo SubjectPublicKeyInfo,  
    issuerUniqueID [1] IMPLICIT UniqueIdentifier  
        OPTIONAL,  
    subjectUniqueID [2] IMPLICIT UniqueIdentifier  
        OPTIONAL,  
    extensions [3] EXPLICIT Extensions  
        OPTIONAL }
```

```
signatureAlgorithm AlgorithmIdentifier,  
signatureValue BIT STRING }
```

Vnitřek certifikátu



Verze

```
Version ::= INTEGER { v1(0), v2(1), v3(2) }
```

Sériové číslo

- Jedinečné v rámci CA
- Dvojice Vydavatel + sériové číslo jednoznačně identifikuje certifikát

`CertificateSerialNumber ::= INTEGER`

Platnost certifikátu

- Platnost do roku 2049 včetně UTCTime, t.j. YYMMDDHHMMSSZ
- platnost od roku 2050 musí být GeneralizedTime, t.j. YYYYMMDDHHMMSSZ

```
Validity ::= SEQUENCE {  
    notBefore      Time,  
    notAfter       Time }  
  
Time ::= CHOICE {  
    utcTime        UTCTime,  
    generalTime    GeneralizedTime }
```

Vydavatel a předmět

Name (Distinguished Name)

```
Name ::= CHOICE {  
    RDNSequence }  
  
RDNSequence ::= SEQUENCE OF RelativeDistinguishedName  
  
RelativeDistinguishedName ::= SET OF AttributeTypeAndValue  
  
AttributeTypeAndValue ::= SEQUENCE {  
    type      AttributeType,  
    value     AttributeValue }  
  
AttributeType ::= OBJECT IDENTIFIER  
  
AttributeValue ::= ANY DEFINED BY AttributeType
```

Jedinečná jména

- **Relativní**

- CommonName (CN) = Jakub Töpfer
- Organization (O) = MFF UK
- Country (C) = CZ

- **Spojeno dohromady**

- CN=Jakub Töpfer, O=MFF UK, C=CZ

- **Stejná konvence jako v LDAP**

Veřejný klíč

SubjectPublicKeyInfo

```
SubjectPublicKeyInfo ::= SEQUENCE {  
  algorithm      AlgorithmIdentifier,  
  subjectPublicKey BIT STRING }
```

Rozšíření certifikátu

Extensions

Extensions ::= SEQUENCE SIZE (1..MAX) OF Extension

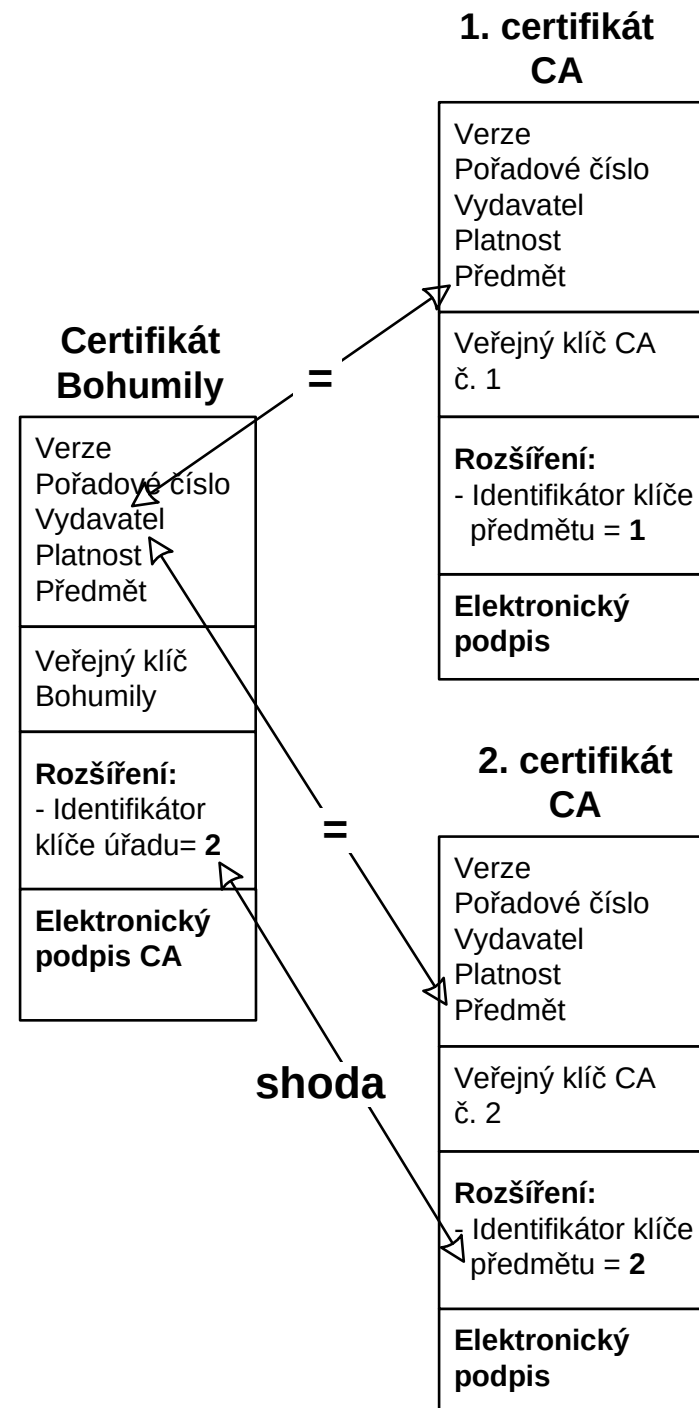
Extension

**Extension ::= SEQUENCE {
 extnID OBJECT IDENTIFIER,
 critical BOOLEAN DEFAULT FALSE,
 extnValue OCTET STRING }**

Critical extension = pokud klient rozšíření nezná,
musí certifikát odmítnout

Identifikátor klíče

- Rozlišení více certifikátů CA



Identifikátor klíče

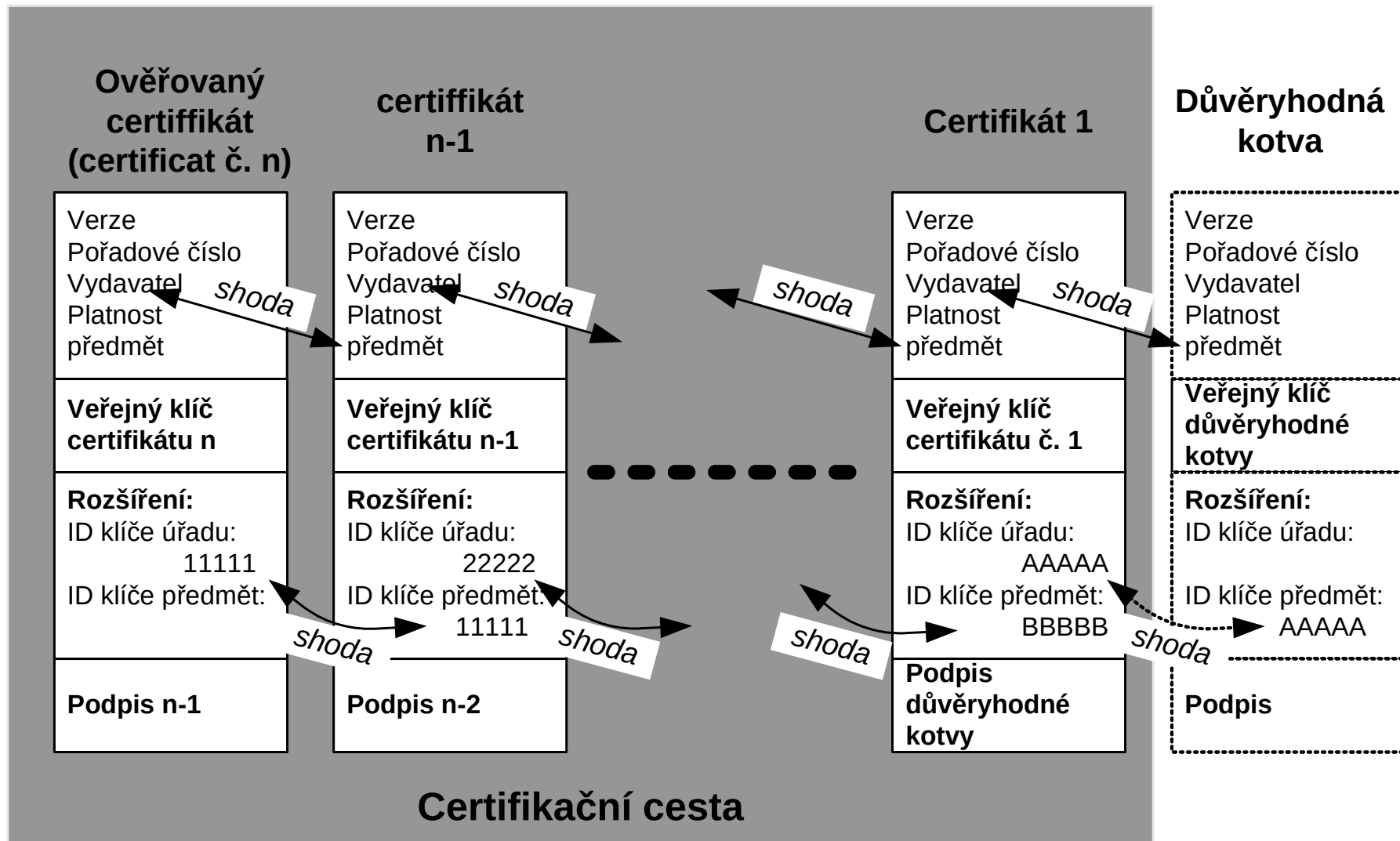
AuthorityKeyIdentifier

```
AuthorityKeyIdentifier ::= SEQUENCE {  
    keyIdentifier          [0] KeyIdentifier OPTIONAL,  
    authorityCertIssuer    [1] GeneralNames   OPTIONAL,  
    authorityCertSerialNumber [2] CertificateSerialNumber OPTIONAL }  
KeyIdentifier ::= OCTET STRING
```

SubjectKeyIdentifier

```
SubjectKeyIdentifier ::= KeyIdentifier  
KeyIdentifier ::= OCTET STRING
```

Sestavení certifikační cesty



Použití klíče

KeyUsage

```
KeyUsage ::= BIT STRING {  
    digitalSignature      (0),  
    nonRepudiation       (1),  
    keyEncipherment      (2),  
    dataEncipherment     (3),  
    keyAgreement         (4),  
    keyCertSign          (5),  
    cRLSign              (6),  
    encipherOnly         (7),  
    decipherOnly         (8) }
```

Použití klíče

- **digitalSignature** – elektronický podpis (např. pro autentizaci). Neumožňuje podepisovat certifikáty a CRL.
- **nonRepudation** – nepopíratelný elektronický podpis. Opět neumožňuje podpis certifikátů a CRL.
- **keyEncipherment** – šifrování klíčů. Obvykle data šifrována symetricky, asymetricky šifrován klíč pro symetrickou šifru.
- **dataEncipherment** – šifrování uživatelských dat jiných než jsou kryptografické klíče.
- **keyAgreement** – veřejný klíč je určen pro algoritmy založené na výměně klíčů (např. Diffie-Hellman).
- **keyCertSign** – podepisování certifikátů.
- **cRLSign** – podepisování seznamu odvolaných certifikátů.

Alternativní jméno předmětu

SubjectAltName

SubjectAltName ::= GeneralNames

GeneralNames ::= SEQUENCE SIZE (1..MAX) OF GeneralName

GeneralName ::= CHOICE {

otherName	[0]	OtherName,
rfc822Name	[1]	IA5String,
dNSName	[2]	IA5String,
x400Address	[3]	ORAddress,
directoryName	[4]	Name,
ediPartyName	[5]	EDIPartyName,
uniformResourceIdentifier	[6]	IA5String,
iPAddress	[7]	OCTET STRING,
registeredID	[8]	OBJECT IDENTIFIER }

OtherName ::= SEQUENCE {

type-id	OBJECT IDENTIFIER,
value	[0] EXPLICIT ANY DEFINED BY type-id }

Basic constraints

- Zda jde o CA
- Zda lze certifikátem podepsat certifikát CA – hloubka cesty

BasicConstraints

```
BasicConstraints ::= SEQUENCE {  
    CA                      BOOLEAN DEFAULT FALSE,  
    pathLenConstraint       INTEGER (0..MAX) OPTIONAL }
```

Další rozšíření

- CertificatePolicies
- PolicyMappings
- CRL, OCSP
- ...

Životní cyklus certifikátu

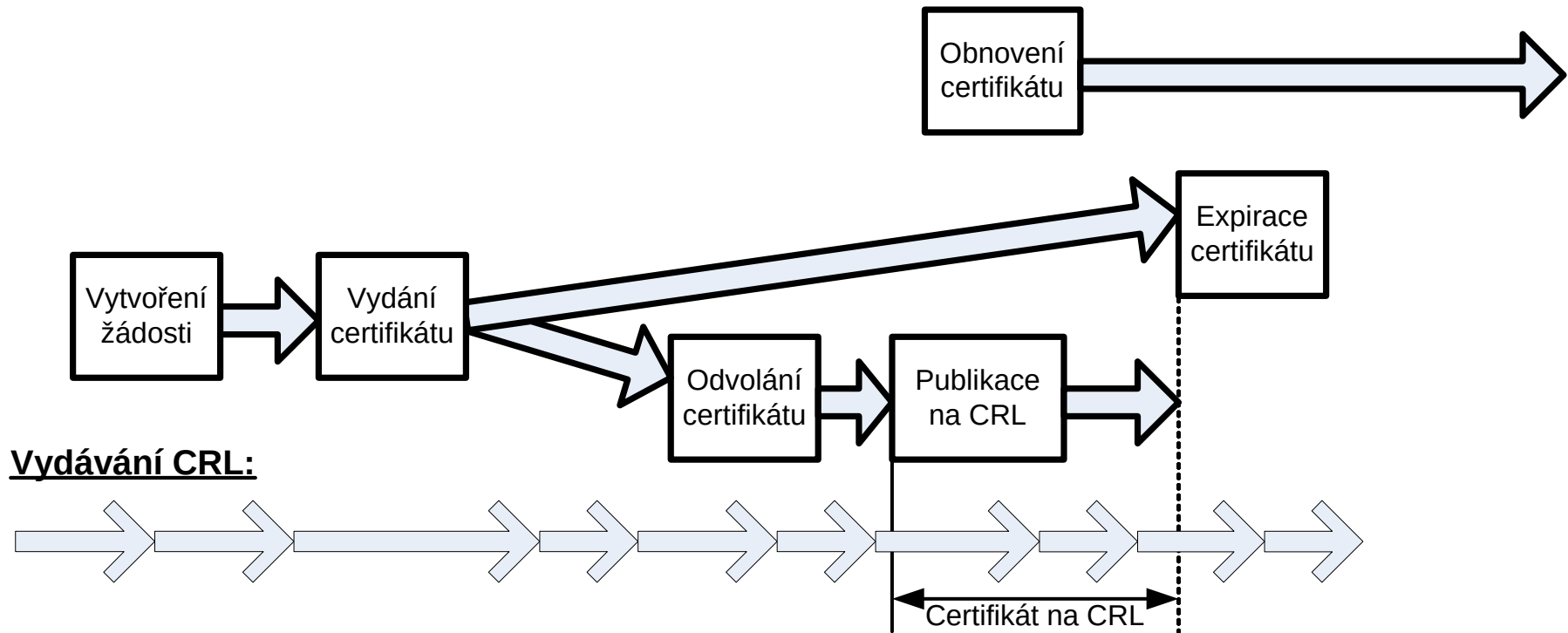


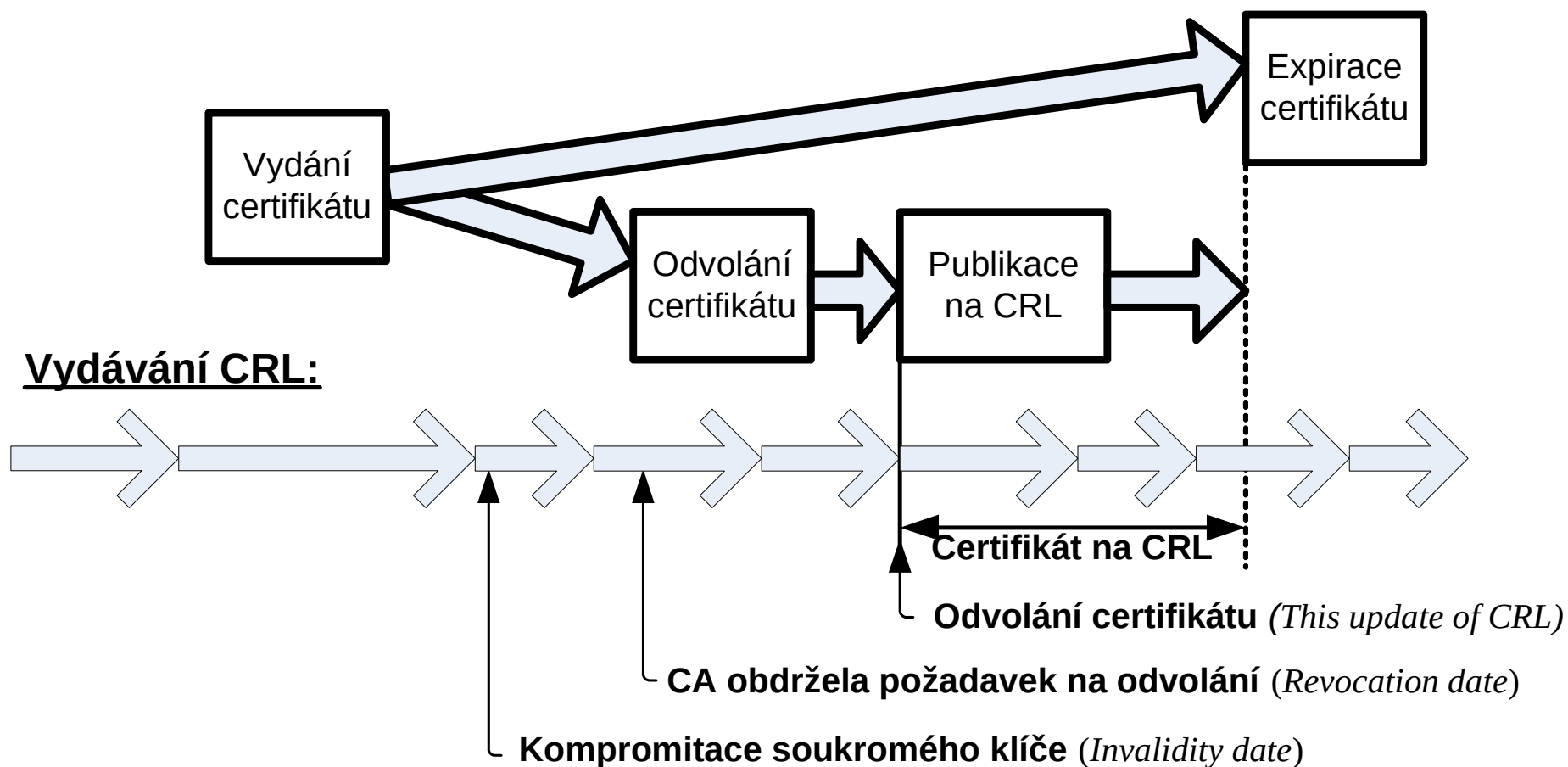
Schéma: Libor Dostálek

Odvolaný certifikát se neobnovuje

Obnovení certifikátu

- **Renew**
- **Rekey** = jako renew, navíc nový privátní klíč
- Identifikace možná pomocí starého, ale ještě platného, certifikátu.

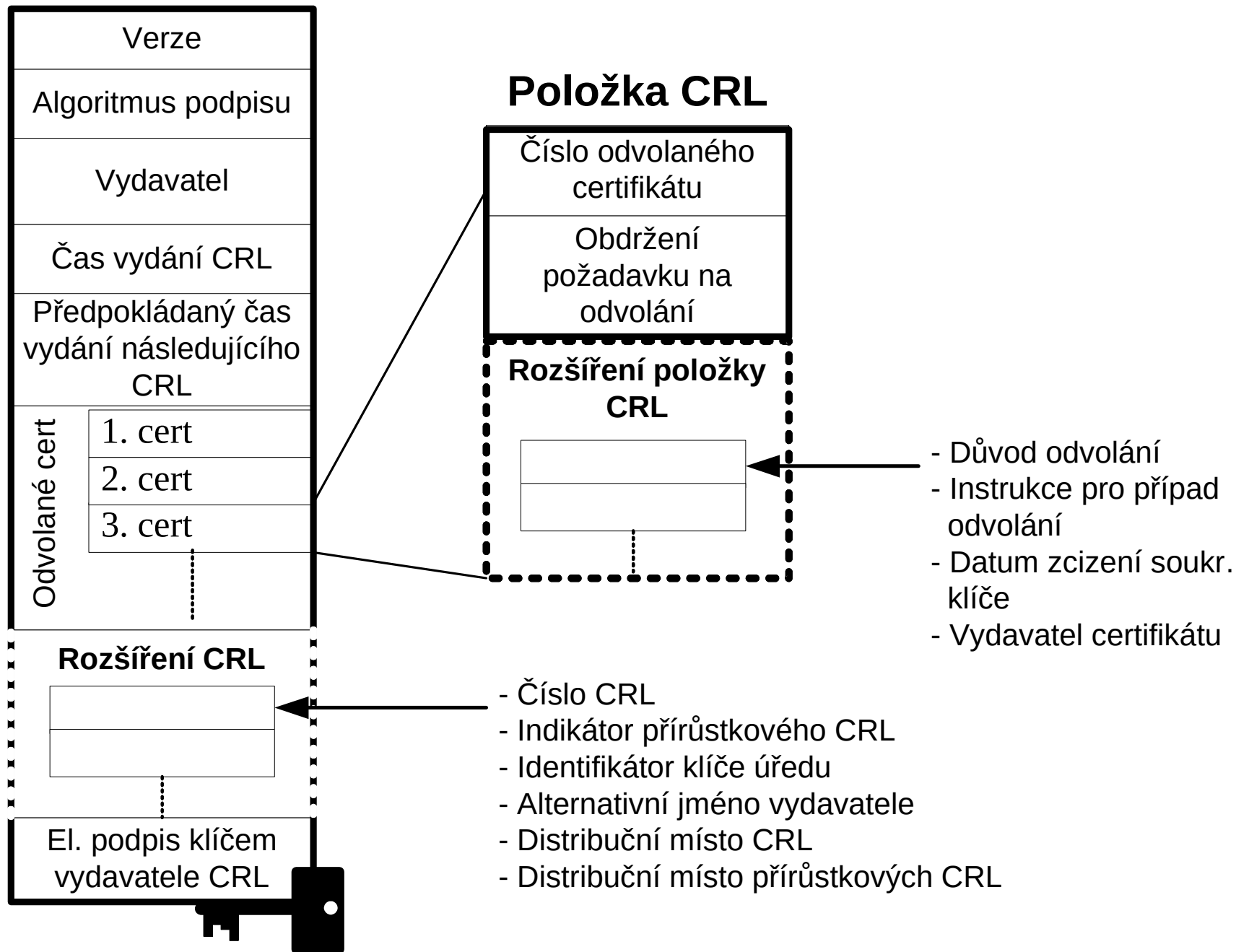
Odvolání certifikátu



CRL

- CRL = Certificate Revocation List
- Typicky vydáváno v pravidelných intervalech
- **Úplné CRL** = všechny odvolané stále platné certifikáty
- **Rozdílové CRL** = všechny odvolané certifikáty od posledního úplného CRL
- **Omezené CRL** = podmnožina např. podle typu

CRL



Rozšíření certifikátu pro CRL

DistributionPoints

CRLDistributionPoints ::= SEQUENCE SIZE (1..MAX) OF DistributionPoint

DistributionPoint ::= SEQUENCE {
 distributionPoint **[0]** **DistributionPointName OPTIONAL,**
 reasons **[1]** **ReasonFlags OPTIONAL,**
 cRLIssuer **[2]** **GeneralNames OPTIONAL }**

DistributionPointName ::= CHOICE {
 fullName **[0]** **GeneralNames,**
 nameRelativeToCRLIssuer **[1]** **RelativeDistinguishedName }**

ReasonFlags ::= BIT STRING {
 unused **(0),**
 keyCompromise **(1),**
 cACompromise **(2),**
 affiliationChanged **(3),**
 superseded **(4),**
 cessationOfOperation **(5),**
 certificateHold **(6),**
 privilegeWithdrawn **(7),**
 aACompromise **(8) }**

Rozšíření pro rozdílová CRL

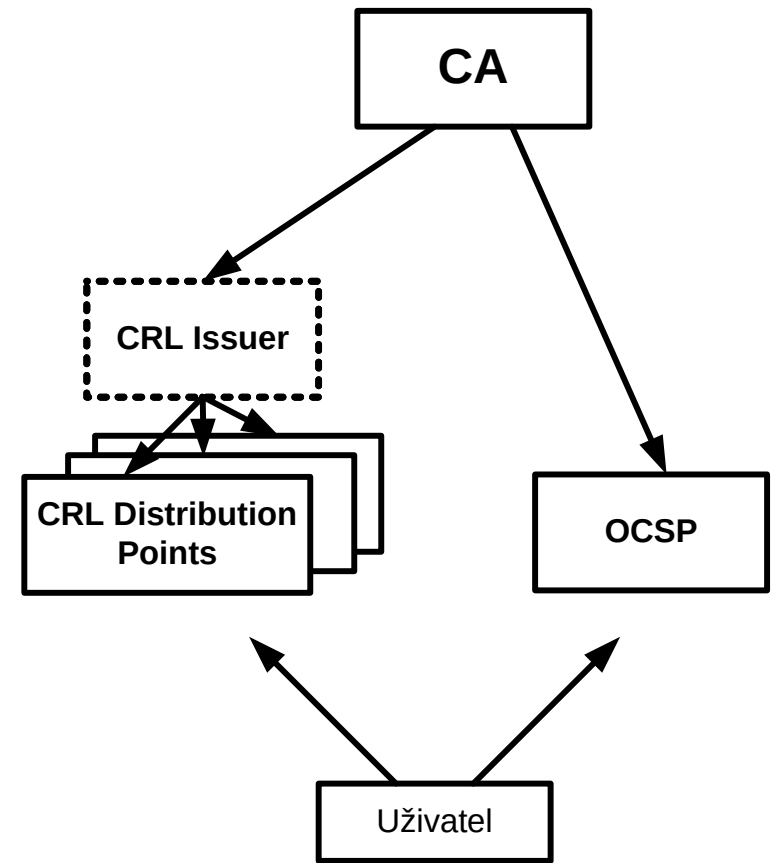
FreshestCRL

FreshestCRL ::= CRLDistributionPoints

Vždy je nutné zkoumat úplná i rozdílová CRL.

OCSP

- Online Certificate Status Protocol
- On-line alternativa k CRL, přímý dotaz na jeden certifikát → méně dat, rychlejší publikace změn



Rozšíření Authority Info (AIA)

- Nalezení certifikátu vydávající CA
- Informace o OCSP

```
AuthorityInfoAccessSyntax ::=  
    SEQUENCE SIZE (1..MAX) OF AccessDescription
```

```
AccessDescription ::= SEQUENCE {  
    accessMethod          OBJECT IDENTIFIER,  
    accessLocation        GeneralName }
```

```
id-ad-ocsp          OBJECT IDENTIFIER ::= { id-ad 1 }  
id-ad-caIssuers     OBJECT IDENTIFIER ::= { id-ad 2 }
```

OCSP stapling

- OCSP responderů mohou být přetížené a pomalé
- Server hostující web může pravidelně žádat o podepsaný OCSP status a ten rovnou zaslat klientovi spolu s certifikátem

Shrnutí možností

